

Relatório de Impacto à Proteção de Dados Pessoais

Versão: 1.0

Última atualização: 04 de maio de 2026

1. AGENTES DE TRATAMENTO E GOVERNANÇA

O presente Relatório de Impacto à Proteção de Dados Pessoais (RIPD) refere-se ao sistema Echoes, desenvolvido com finalidade educacional, voltado à simulação clínica em ambiente acadêmico com suporte a dispositivos IoT.

São definidos como agentes de tratamento:

- **Controlador:** Equipe de Desenvolvimento do Projeto Echoes / Universidade de Mogi das Cruzes
- **Operadores:** Infraestrutura do Servidor Echoes (ambiente em nuvem), Aplicação (App) e Dispositivos IoT integrados
- **Encarregado de Dados (DPO):** Fabiano Bezerra Menegidio
- **Partes Interessadas:** Professores, alunos e administradores usuários da plataforma

A governança de dados é estruturada com base em princípios de segurança, necessidade, transparência e responsabilização, conforme previsto na Lei Geral de Proteção de Dados Pessoais (Lei nº 13.709/2018).

2. NECESSIDADE E JUSTIFICATIVA

A elaboração deste relatório atende ao disposto no Art. 38 da LGPD, sendo necessária em razão do tratamento contínuo e estruturado de dados pessoais no sistema, incluindo:

- Dados cadastrais de usuários (professores, alunos e administradores)
- Dados de autenticação e segurança (senhas, tokens, MFA)
- Dados de rastreamento técnico (endereço IP e logs de auditoria)

Além disso, a integração com serviços externos (como envio de e-mails para autenticação multifator) e a utilização de dispositivos IoT aumentam a superfície de risco, justificando uma análise aprofundada de impacto.

DESCRIÇÃO DETALHADA DO TRATAMENTO DE DADOS

O sistema Echoes realiza o tratamento de dados pessoais com o objetivo de viabilizar a operação de uma plataforma educacional interativa, permitindo simulações clínicas com base em cenários anatômicos.

Ciclo de Vida dos Dados

O ciclo de vida dos dados no sistema compreende:

- **Coleta:** Realizada por meio de formulários no aplicativo ou servidor, incluindo nome, e-mail, senha e perfil do usuário.
- **Processamento:** Inclui autenticação via tokens JWT, validação por MFA, controle de acesso por perfil e execução de cenários clínicos.
- **Armazenamento:** Remoto: Banco de dados em servidor seguro. Local: Dispositivo do usuário (Android DataStore) e memória de dispositivos IoT (ex: ESP32).
- **Compartilhamento:** Interno entre módulos do sistema. Externo limitado a serviços de envio de e-mail (para MFA e notificações), podendo envolver transferência internacional.
- **Eliminação:** O sistema prevê exclusão de dados mediante solicitação do titular, incluindo remoção definitiva de contas e registros associados.

CATEGORIAS DE DADOS TRATADOS

O tratamento envolve diferentes categorias de dados, classificadas conforme sua natureza e sensibilidade:

Dados Pessoais Identificáveis

- Nome
- Endereço de e-mail
- Endereço IP
- Identificador único do usuário

Dados de Autenticação e Segurança

- Senha (armazenada com hash BCrypt e salt)
- Tokens JWT de acesso
- Códigos MFA temporários

Dados Operacionais

- Logs de auditoria
- Perfis de acesso
- Lista de tokens revogados
- Aceite de termos de uso

Dados Financeiros

- Dados bancários armazenados de forma criptografada

Dados Não Pessoais

- Dados de cenários clínicos
- Configurações de dispositivos IoT
- Modelos anatômicos

FINALIDADE DO TRATAMENTO

O tratamento de dados pessoais ocorre para finalidades específicas e legítimas, incluindo:

- Identificação e autenticação de usuários
- Controle de acesso e permissões
- Execução de simulações clínicas educacionais
- Organização de turmas e atividades acadêmicas
- Comunicação com usuários (notificações e MFA)
- Monitoramento de segurança e prevenção a fraudes
- Registro de consentimento e conformidade legal

BASES LEGAIS - Lei Geral de Proteção de Dados

O tratamento de dados está fundamentado nas seguintes bases legais previstas no Art. 7º da LGPD:

- Execução de contrato: prestação do serviço educacional
- Legítimo interesse: garantia da segurança da plataforma
- Consentimento: obtido no momento do cadastro e aceite dos termos
- Cumprimento de obrigação legal: manutenção de registros e auditoria

ANÁLISE DE RISCOS À PRIVACIDADE

A análise de riscos considera a probabilidade de ocorrência e o impacto sobre os direitos dos titulares.

Principais Riscos Identificados

- Acesso não autorizado: comprometimento de contas de usuários
- Ataques de força bruta: tentativas automatizadas de quebra de senha
- Vazamento de dados: exposição de informações pessoais ou tokens
- Intercepção de dados: tráfego indevido em rede
- Coleta excessiva: tratamento além do necessário

Classificação Geral de Risco

O sistema apresenta risco residual classificado entre baixo e moderado, com pontos de atenção concentrados em autenticação e segurança de acesso.

MEDIDAS DE SEGURANÇA E MITIGAÇÃO

O sistema adota um conjunto robusto de medidas técnicas e organizacionais para mitigação de

riscos.

Segurança Técnica

- **Criptografia:**
 - Senhas com BCrypt + salt
 - Tokens protegidos com AES (Android Keystore)
- **Comunicação Segura:**
 - HTTPS/TLS obrigatório
 - Política HSTS
- **Autenticação:**
 - MFA obrigatório
 - Tokens JWT com expiração e assinatura segura
- **Proteção contra ataques:**
 - *Rate limiting* por IP
 - Bloqueio após tentativas inválidas
 - Revogação de tokens

Monitoramento e Auditoria

- Logs estruturados com rastreabilidade
- Registro de IP, data e eventos
- Mascaramento de dados sensíveis
- Auditoria contínua de ações

Governança e Conformidade

- Registro de consentimento por versão de termos
- Possibilidade de revogação de consentimento

Princípio da minimização de dados

- Controle de acesso baseado em perfil

NECESSIDADE, ADEQUAÇÃO E PROPORCIONALIDADE

O tratamento realizado pelo sistema:

- É necessário para funcionamento da plataforma
- É adequado às finalidades educacionais propostas
- É proporcional, limitando-se ao mínimo de dados exigidos

Não foram identificadas práticas de coleta excessiva ou desnecessária.

DIREITOS DOS TITULARES

O sistema assegura mecanismos para:

- Registro de consentimento
- Revogação de consentimento
- Exclusão de dados mediante solicitação
- Rastreabilidade de ações

IMPACTOS À PRIVACIDADE

Impactos Positivos

- Elevado nível de segurança na autenticação
- Transparência no tratamento de dados
- Controle granular de acesso

Impactos Potenciais Negativos

- Dependência de serviços externos (e-mail)
- Centralização de dados em servidor
- Riscos inerentes à autenticação digital

MEDIDAS ADICIONAIS RECOMENDADAS

Para aprimoramento contínuo:

- Implementação de anonimização em logs
- Testes periódicos de segurança (*pentest*)
- Política formal de retenção e descarte de dados
- Plano estruturado de resposta a incidentes
- Avaliação contínua de fornecedores externos

Metodologia de Avaliação de Riscos

A avaliação de riscos do sistema segue uma metodologia qualitativa e semi-quantitativa baseada na combinação entre probabilidade de ocorrência e impacto sobre os direitos dos titulares.

Escala de Probabilidade:

- Baixa (1): evento improvável
- Média (2): evento possível
- Alta (3): evento provável

Escala de Impacto:

- Baixo (1): impacto limitado ao sistema
- Médio (2): impacto moderado ao titular
- Alto (3): impacto significativo aos direitos fundamentais

Classificação do Risco:

Risco = Probabilidade × Impacto

- 1–2: Baixo
- 3–4: Médio
- 6–9: Alto

Mapeamento de Fluxo de Dados

O fluxo de dados no sistema ocorre conforme a seguinte estrutura:

- Usuário → Aplicativo (App Echoes): coleta de dados cadastrais e autenticação
- Aplicativo → Backend/API: processamento e validação de credenciais
- Backend → Banco de Dados (Cloud): armazenamento seguro
- Backend → Serviços externos: envio de e-mails (MFA e notificações)
- Backend → Dispositivos IoT (ESP32): envio e recepção de dados clínicos simulados

Localização dos dados:

- Servidores em nuvem (infraestrutura externa)
- Dispositivos móveis (Android DataStore)
- Dispositivos embarcados IoT

Transferência Internacional de Dados

O sistema pode realizar transferência internacional de dados pessoais quando utiliza serviços de terceiros para envio de e-mails e infraestrutura em nuvem.

Possíveis destinos:

- Servidores de provedores de e-mail (ex: Google, Microsoft ou equivalentes)
- Infraestrutura de *cloud computing* localizada fora do Brasil

Garantias adotadas:

- Contratos com cláusulas padrão de proteção de dados
- Criptografia em trânsito (TLS)
- Minimização de dados enviados

Avaliação de Impacto aos Direitos dos Titulares

O tratamento de dados pode impactar os seguintes direitos dos titulares:

- Privacidade e controle sobre dados pessoais
- Risco de acesso não autorizado a informações pessoais
- Possível uso indevido de credenciais em caso de falhas de segurança

Necessidade e Proporcionalidade do Tratamento

O tratamento de dados pessoais é avaliado sob os princípios de necessidade e proporcionalidade:

- **Necessidade:** Os dados coletados são estritamente necessários para autenticação, controle de acesso e execução das simulações educacionais.
- **Proporcionalidade:** Não são coletados dados excessivos além do necessário para funcionamento da plataforma.

Análise de alternativas: A remoção de determinados dados (como e-mail ou autenticação) inviabilizaria o funcionamento seguro do sistema, especialmente no controle de acesso e rastreabilidade.